



KubeCon



CloudNativeCon

North America 2024

Best friends keep no secrets: going secretless with cert-manager



Tim Ramlot

cert-manager maintainer - Software engineer @ Venafi a CyberArk company



Ashley Davis

cert-manager maintainer - Software engineer @ Venafi a CyberArk company

What's cert-manager?

cert-manager is the best way to get X.509 certificates in Kubernetes

- Use Kubernetes API to request certificates
- Automated issuance and renewal
- Usable for both server and client authentication





CNCF graduated project



427+ contributors



12k GitHub stars



20M monthly chart
downloads

We're looking for contributors!

- New contributors always welcome!
- Clear pathway to maintainership!
- Come talk to us after
- Or at the cert-manager booth



<https://cert-manager.io/docs/contributing/>



KubeCon



CloudNativeCon

North America 2024

Best friends keep no secrets: going **secretless** with cert-manager



Tim Ramlot

cert-manager maintainer - Software engineer @ Venafi a CyberArk company



Ashley Davis

cert-manager maintainer - Software engineer @ Venafi a CyberArk company

secretless and Secretless

= no secrets are shared
between machines/
transported over the wire

= no Kubernetes Secret
resources are used





KubeCon

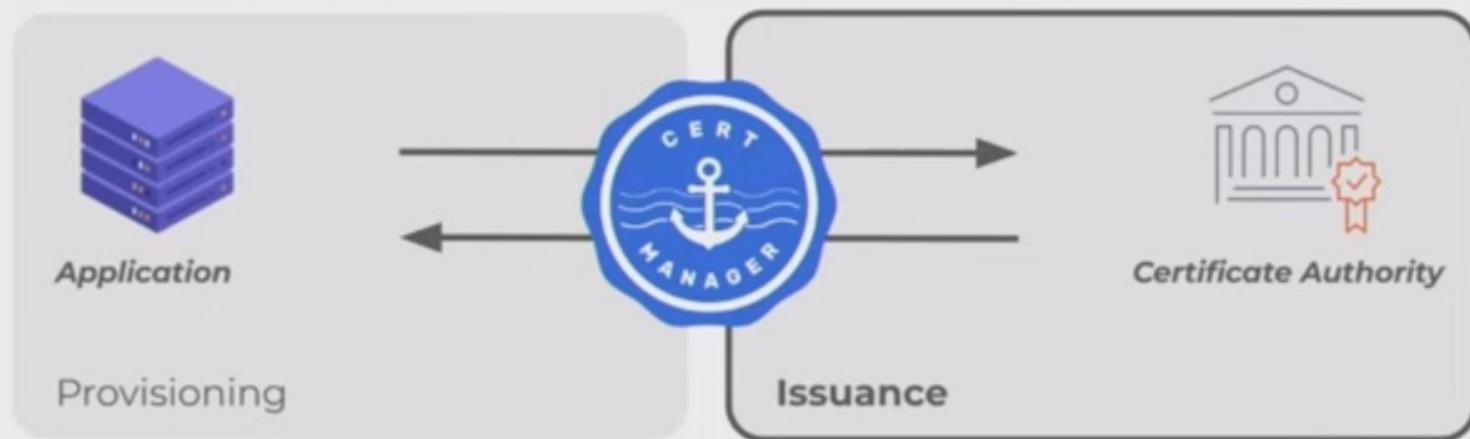


CloudNativeCon

North America 2024

cert-manager Issuance

How does cert-manager issue a certificate?



Integration with external CA
(eg. ACME, Venafi, Vault, AWS, GCP)

- requires **authentication**



Challenge: prove to CA that you own the identity and are allowed to submit this CSR

Simplest Solution: Static Secret

```
apiVersion: cert-manager.io/v1
kind: Issuer
metadata:
  name: my-issuer
spec:
  vault:
    . . .
  auth:
    tokenSecretRef:
      name: my-token
      key: token
```

```
apiVersion: v1
kind: Secret
metadata:
  name: my-token
type: Opaque
data:
  token: "Abc123"
```

Issues with Static Secrets

- Need rotation
- High-value targets
- Usually manually set up
- E.g. Hard to do using GitOps

Better Solution: Workload Identity



Better Solution: Workload Identity

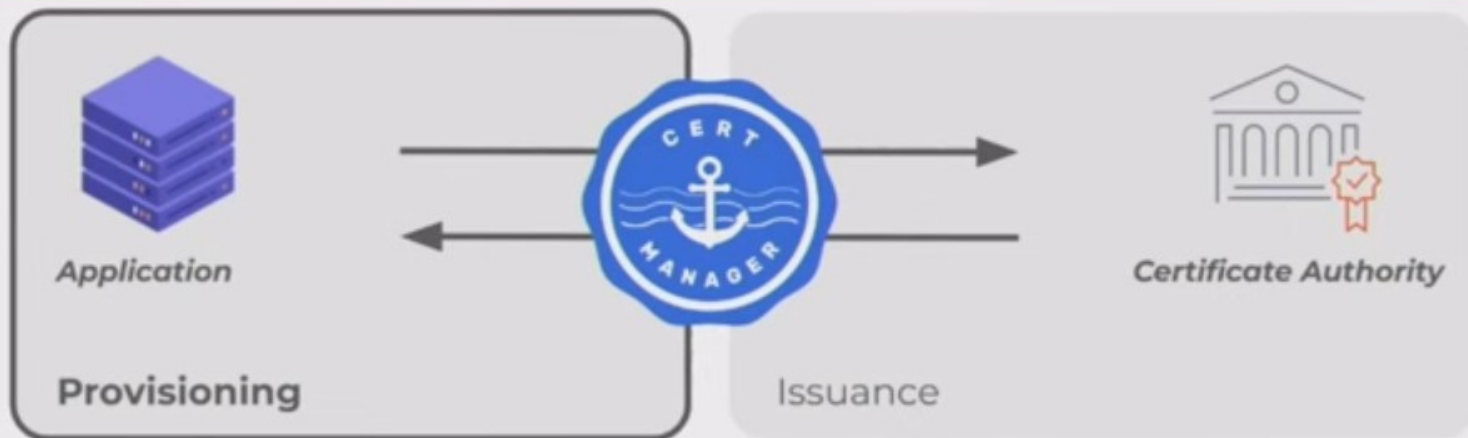
```
apiVersion: cert-manager.io/v1
kind: Issuer
metadata:
  name: my-issuer
  namespace: sandbox
spec:
  vault:
    . . .
  kubernetes:
    . . .
    role: my-role
  serviceAccountRef:
    name: my-sa
```

Workload Identity is “secretless”

	static secret	signed tokens (e.g. JWT)	X.509
Restricting use	none	audience	embedded identity
Restricting validity	none	time-limited one-time-use*	time-limited
How to trust	share the secret	trust public key	trust public key
How to use	share the secret	share the JWT	use private key

cert-manager Provisioning

What does cert-manager provision?



X.509 certificate + private key

Provisioned through:

- Kubernetes Secret resource
- CSI Volume mount ([csi-driver](#))
- Service Mesh ([istio-csr](#))

A Secretless certificate

```
apiVersion: v1
kind: Pod
...
spec:
  ...
  volumes:
    - name: spiffe
      csi:
        driver: csi.cert-manager.io
        readOnly: true
        volumeAttributes:
          csi.cert-manager.io/issuer-name: workload-issuer
          csi.cert-manager.io/issuer-kind: ClusterIssuer
          csi.cert-manager.io/issuer-group: cert-manager.io

          csi.cert-manager.io/dns-names: example.com
```

Request and provision certificate directly via Pod mount

- + no secrets in cluster state
- + private key does not leave machine
- new certificate must be issued when pod reschedules



<https://cert-manager.io/docs/usage/csi-driver/>

Demo



Demo



Recap: Going Secretless

- Auth is important!
 - How does cert-manager authenticate for you?
 - Avoid static secrets, if possible
- Reduce use of Secrets with csi-driver
 - More details on cert-manager.io
 - Works great with private PKI!

Outro: Thank you!

Questions?

Feedback:

